Kriptográfia és biztonság 3.

Véletlen és társai

Emlékeztető: tökéletes biztonság

Informális tulajdonságok

Egy titkosítás tökéletesen biztonságos, ha törhetetlen

- tetszőleges időben
- tetszőleges számítási kapacitással

One-time pad

- üzenet és titkosszöveg egyforma hosszú
- titkos kulcs egyszer használatos
- támadó nem ismeri a kulcsot
- **a titkos kulcs valódi véletlen**

Véletlen sorozatok

Véletlen sorozatok elvárt tulajdonságai

- egyes karakterek uniform eloszlása egy adott intervallum felett
- jövőbeli értékeket lehetetlen megjósolni a korábbi/jelenlegi alapján
- egymást követő karakterek között nincs összefüggés

Kérdés

Hogyan definiáljuk egy sorozat véletlenségét?

Vannak-e valódi véletlen sorozatok?

- s_1=111111111111111111111111111111111111111111
- s_2=111111111111111111111000000000000000000000
- s_3=101010101010101010101010101010101010101010
- s_4=100011101011000011101010101110001110111110

Vannak-e valódi véletlen sorozatok?

- s_1=111111111111111111111111111111111111111111
- s_2=111111111111111111111000000000000000000000
- s_3=101010101010101010101010101010101010101010
- s_4=100011101011000011101010101110001110111110

Vannak-e valódi véletlen sorozatok?

- s_1=1111111111111111111111111111111111111111111111
- s_2=1111111111111111111111000000000000000000000000
- s_3=1010101010101010101010101010101010101010101010
- s_4=1000111010110000111010101011100011101111110

Vannak-e valódi véletlen sorozatok?

- s_1=1111111111111111111111111111111111111111111111
- s_2=1111111111111111111111000000000000000000000000
- s_3=1010101010101010101010101010101010101010101010
- s_4=1000111010110000111010101011100011101111110

Véletlen sorozatok

Definíció

Kolmogorov bonyolultság Jelölje $d(s)$ az s sorozat minimális leírását valamely $\mathcal{L}$ univerzális nyelven. Az s ***Kolmogorov bonyolultsága*** *ennek a leírásnak a hossza: $K(s) = |d(s)|$.*

Definíció

Egy s sorozat ***algoritmikusan véletlen****, ha $|s| < K(s)$.*

Magyarul

Véletlen sorozat nem tömöríthető.

Vannak-e valódi véletlen sorozatok?

- s_1=111111111111111111111111111111111111111111

  s_1 rövid magyar leírása "1 42-szer" ami 9 karakter. s_1-et tömörítettük, tehát nem véletlen.

- s_4=100011101011000011101010101110001110111110

  s_4 véletlennek **tűnik** és nem tömöríthető.

Kolmogorov bonyolultság

Theorem

Nem létezik program, ami bármely s-re kiszámítja a $K(s)$ értéket.

Tegyük fel, hogy mégis: az KolmogorovComplexity(s) függvény s input sorozaton kiszámítja $K(s)$-t. Tfh. az algoritmus leírható 100.000 biten.

---

for $i = 1 \rightarrow \infty$ **do**
  for each s sorozatra $\forall i$ hosszúsággal **do**
    if KolmogorovComplexity(s)≥ 200.000 **then**
      return s
    end if
  end for
end for

Véletlen sorozatok generálása

Idézet

"Bárki, aki aritmetikai módszerekkel akar előállítani egy véletlenszámot, a bűn állapotában leledzik." – Neumann János

Következmény

Nem létezik matematikai algoritmus, ami valódi véletlent képes előállítani.

Tulajdonságok

- fizikai forrásból
- gyenge véletlen = sebezhetőség a kódban!!!

Számítási biztonság

Kerckhoff elvek

1. kriptorendszer legyen gyakorlatban törhetetlen, ha matematikailag nem
2. ...

Ötlet

Tökéletes biztonságú titkosítás helyett olyan, ami nem törhető

- "értelmes időben"
- "értelmes eséllyel"

Számítási biztonság

Értelmes időben = ???

- hatékony támadó
- hatékony számítások

Definíció

*Egy A algoritmus **polinom idejű**, ha $\exists$ egy $p(.)$ polinom, amire $\forall x \in \{0,1\}^*$ input esetén, az $A(x)$ számítása $\leq p(|x|)$ lépésben terminál.*

Definíció

*Egy A algoritmus **probabilisztikus**, ha hozzáfér egy véletlen forráshoz, ami független, egyenletes véletlen biteket generál.*

Hatékony támadó

Probabilisztikus polimon idejű (**PPT**) támadó.

Számítási biztonság

Értelmes időben = ???

- hatékony támadó
- hatékony számítások

Definíció

*Egy A algoritmus **polinom idejű**, ha $\exists$ egy $p(.)$ polinom, amire $\forall x \in \{0,1\}^*$ input esetén, az $A(x)$ számítása $\leq p(|x|)$ lépésben terminál.*

Definíció

*Egy A algoritmus **probabilisztikus**, ha hozzáfér egy véletlen forráshoz, ami független, egyenletes véletlen biteket generál.*

Hatékony támadó

Probabilisztikus polimon idejű (**PPT**) támadó.

Számítási biztonság

Értelmes eséllyel = ???

- nagyon kis valószínűséggel
- elhanyagolható siker-valószínűséggel

Definíció

*Az f függvény **elhanyagolható**, ha $\forall p(.)$ polinomhoz $\exists N \in \mathbb{R}^+$, amire $\forall n \in \mathbb{N}, n > N$ teljesül, hogy $f(n) < \frac{1}{p(n)}$.*

Esélytelen támadó

Elhanyagolható valószínűséggel sikeres a törés.

Számítási biztonság - 2 megközelítés

Konkrét megközelítés

Egy rendszer (t, ε)-biztonságos, ha $\forall$ legfeljebb t futási idejű támadó legfeljebb ε valséggel töri a rendszert.

Aszimptotikus megközelítés

Egy rendszer biztonságos, ha $\forall$ PPT támadó elhanyagolható valséggel töri a rendszert.

Redukciós bizonyítások

- feltétel nélküli biztonság korlátai
- számítási biztonságnál kell valami feltétel
- thf. egy alacsony szintű probléma nehéz
- ekkor adott konstrukció biztonságos

Redukciós biztonsági bizonyítások

- ha $\exists \mathcal{A}$ PPT támadó, aki nem elhanyagolható valséggel töri a rendszert
- akkor $\exists \mathcal{A}'$ PPT algoritmus, ami megoldja a nehéz problémát

(Számítási) biztonságos titkosítási séma

Definíció

Egy titkosítási séma egy $\Pi = (Gen, Enc, Dec)$ *hármas, amire:*

- Gen *a kulcsgenerálás, egy valószínűségi algoritmus, ami adott* 1^n *biztonsági paraméterre egy* $k \in_R \mathcal{K}$ *kulcsot ad vissza, amire* $|k| \geq n$
- Enc *a titkosítás, egy valószínűségi algoritmus, ami* $k \in \mathcal{K}$ *kulcs és* $m \in \{0,1\}^*(\{0,1\}^{l(n)})$ *üzenet esetén egy* $c \in \mathcal{C}$ *titkosszöveget ad vissza:* $c := Enc_k(m)$.
- Dec *a visszafejtés egy determinisztikus algoritmus, ami adott* k *kulcs és* $c \in \mathcal{C}$ *esetén* $\mathcal{M}$ *egy elemét adja vissza:* $Dec_k(c)$.

Fenyegetés modell

Passzív támadó: egyetlen titkos szöveg lehallgatása

(Számítási) biztonságos titkosítási séma

Támadás

- az $\mathcal{A}$ támadó lehallgathat
- egyetlen titkos szöveg
- passzív támadás
- cél: $\mathcal{A}$ semmilyen információt nem tud meg m-ről
  - *szemantikai biztonság*
  - nehéz kezelni
- helyette: **megkülönböztethetlenség**

(Számítási) biztonságos titkosítási séma

Definíció (1 lehallgatás megkülönböztethetetlenség kísérlet $PrivK^{eav}_{\mathcal{A},\Pi}(n)$)

1. *az $\mathcal{A}$ támadó 1^n inputra kiad m_0, m_1 üzeneteket, amire $|m_0| = |m_1|$*
2. $k = Gen(1^n), b \in_R \{0,1\} : c = Enc_k(m_b)$ *ezt megkapja $\mathcal{A}$*
3. *$\mathcal{A}$ kiad $b' \in \{0,1\}$*
4. $PrivK^{eav}_{\mathcal{A},\Pi}(n) = 1$, *ha $b = b'$, és 0 egyébként*

Definíció

Egy $\Pi = (Gen, Enc, Dec)$ titkosítás megkülönböztethetetlen 1 lehallgatás esetén, ha $\forall \mathcal{A}$ PPT támadóra $\exists e(.)$ elhanyagolható függvény, amire

$$P(PrivK^{eav}_{\mathcal{A},\Pi}(n) = 1) \leq \frac{1}{2} + e(n).$$

Pszeudovéletlenség

Ötlet

- one-time pad ötletét használjuk
- tökéletes helyett számítási biztonság
- véletlen sorozat helyett ???

Pszeudovéletlen sorozat

- pseudorandom vagy röviden PR
- számítási relaxációja a valódi véletlennek
- pszeidovéletlen sorozat egyenletes valódi véletlennek *látszik* (PPT szemszögből)
- rövid, valódi véletlen sorozatból (seed) generálva

Pszeudovéletlenség

Ötlet

- one-time pad ötletét használjuk
- tökéletes helyett számítási biztonság
- véletlen sorozat helyett ???

Pszeudovéletlen sorozat

- pseudorandom vagy röviden PR
- számítási relaxációja a valódi véletlennek
- pszeidovéletlen sorozat egyenletes valódi véletlennek *látszik* (PPT szemszögből)
- rövid, valódi véletlen sorozatból (seed) generálva

Pszeudovéletlenség

Intuíció

- tartalmaz valami rövid véletlent, de maga a sorozat jóval hosszabb
- értelmes időben nem lehet megkülönböztetni a valódi véletlentől

Definíció

Legyen $l(.)$ polinom (expanziós faktor) és $G : \{0,1\}^n \to \{0,1\}^{l(n)}$ DPT algoritmus. Ekkor G egy pszeudovéletlen generátor, ha

1. $\forall n : l(n) > n$
2. $\forall D$ *PPT megkülönböztetőre* $\exists e(.)$ *elhanyagolható függvény, amire* $s \in_R \{0,1\}^n, r \in_R \{0,1\}^{l(n)}$ *esetén*

$$|Pr(D(r) = 1) - Pr(D(G(s)) = 1)| \leq e(n)$$

Pszeudovéletlenség

Intuíció

- tartalmaz valami rövid véletlent, de maga a sorozat jóval hosszabb
- értelmes időben nem lehet megkülönböztetni a valódi véletlentől

Definíció

Legyen $l(.)$ *polinom (expanziós faktor) és* $G : \{0,1\}^n \to \{0,1\}^{l(n)}$ *DPT algoritmus. Ekkor* G *egy pszeudovéletlen generátor, ha*

1. $\forall n : l(n) > n$
2. $\forall D$ *PPT megkülönböztetőre* $\exists e(.)$ *elhanyagolható függvény, amire* $s \in_R \{0,1\}^n, r \in_R \{0,1\}^{l(n)}$ *esetén*

$$|Pr(D(r) = 1) - Pr(D(G(s)) = 1)| \leq e(n)$$

Pszeudovéletlenség

Tulajdonságok

- PRG messze van a valódi véletlentől
- Brute force mindig működik
- Seed jellemzők:
  - valódi véletlen
  - titokban kell tartani
  - nem túl rövid
- PRG létezik a szokásos nehézségi feltevések mellett
- statisztikai tesztek

Next-bit teszt

Next-bit teszt

Egy bitsorozat átmegy a next-bit teszten, ha a sorozat $\forall i$. pozíciójára, ha a támadó

- az első i bitet ismereti
- az $(i+1)$. bitet nem tudja $50\% + \epsilon$-nál nagyobb valószínűséggel megtippelni

Statisztikai tesztek

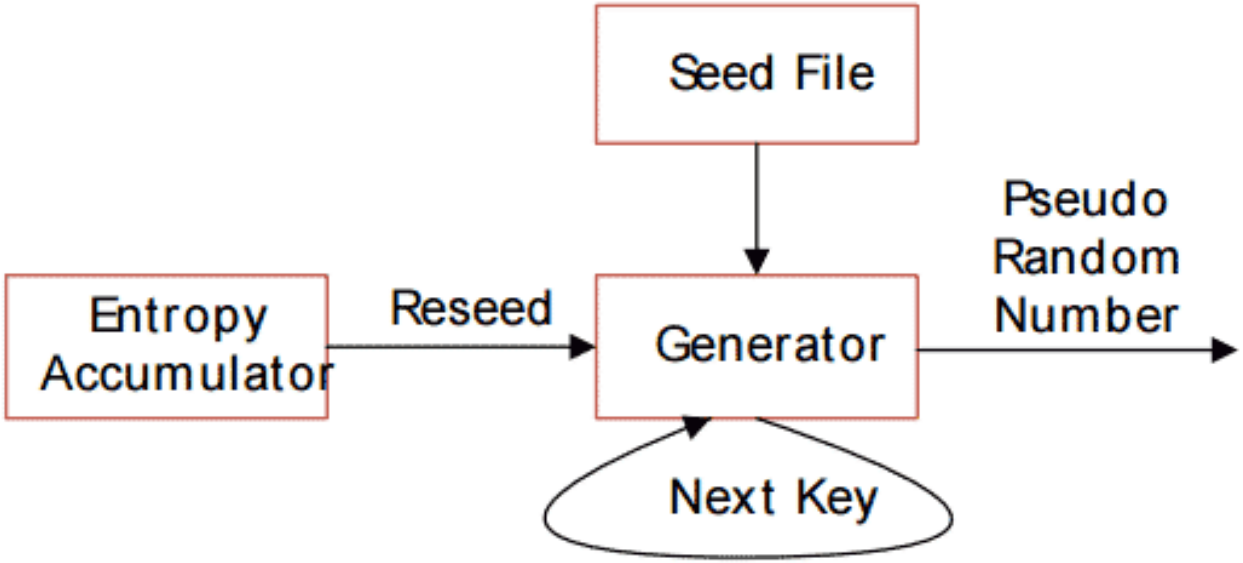
- NIST teszt (Amerikai Szabványügyi Hivatal fejlesztése)
- DIEHARD teszt (akadémiai fejlesztés – Marsaglia '95)

PRG példa: Fortuna

Fortuna

- Schneier és Fergusson ’03
- PRG család 3 fő komponenssel:

1. **Generátor**: PR folyam előállítása seedelés esetén
2. **Entrópia akkumulátor**: véletlenség összegyűjtése
3. **Seedelés**: boot lépésben biztosítja a véletlenséget



Egy lehallgatás ellen biztonságos titkosítási séma

Titkosítás PRG-ből

Legyen G egy l expanziós faktorú PRG, valamint

- **Gen** $k \in_R \{0,1\}^n$
- **Enc** adott $k \in \{0,1\}^n$ kulcs és $m \in \{0,1\}^{l(n)}$ üzenet esetén $c = Enc_k(m) = G(k) \oplus m$.
- **Dec** adott k kulcs és $c \in \{0,1\}^{l(n)}$ titkosszöveg esetén $Dec_k(c) = c \oplus G(k)$.

Tétel

Ha G PRG, akkor a fenti $\Pi = (Gen, Enc, Dec)$ titkosítás megkülönböztethetetlen 1 lehallgatás esetén.

Több lehallgatás ellen biztonságos titkosítási séma

Definíció (Többszörös lehallgatás megkülönböztethetetlenség kísérlet $PrivK^{meav}_{\mathcal{A},\Pi}(n)$)

Ugyanaz, mint 1 lehallgatásnál, kivéve:

1. *az $\mathcal{A}$ támadó 1^n inputra kiad* $M_0 = (m_{01}, \ldots, m_{0t}), M_1 = (m_{11}, \ldots, m_{1t})$ *üzenet-sorozatokat, amire* $\forall i : |m_{0i}| = |m_{1i}|$
2. $k = Gen(1^n), b \in_R \{0,1\} : C = (c_1, \ldots, c_t) : c_i = Enc_k(m_{bi})$ *ezt megkapja $\mathcal{A}$*

- $\exists$ titkosítás, ami 1 lehallgatásnál bizt, de többnél nem
- determinisztikus algoritmus sosem lesz jó $\Rightarrow$ randomizálás
- szinkronizálás
- $Enc_k(m) = (IV, G(m, IV) \oplus m)$

Több lehallgatás ellen biztonságos titkosítási séma

Definíció (Többszörös lehallgatás megkülönböztethetetlenség kísérlet $PrivK^{meav}_{\mathcal{A},\Pi}(n)$)

Ugyanaz, mint 1 lehallgatásnál, kivéve:

1. *az $\mathcal{A}$ támadó 1^n inputra kiad* $M_0 = (m_{01}, \ldots, m_{0t}), M_1 = (m_{11}, \ldots, m_{1t})$ *üzenet-sorozatokat, amire* $\forall i : |m_{0i}| = |m_{1i}|$
2. $k = Gen(1^n), b \in_R \{0,1\} : C = (c_1, \ldots, c_t) : c_i = Enc_k(m_{bi})$ *ezt megkapja $\mathcal{A}$*

- $\exists$ titkosítás, ami 1 lehallgatásnál bizt, de többnél nem
- determinisztikus algoritmus sosem lesz jó $\Rightarrow$ randomizálás
- szinkronizálás
- $Enc_k(m) = (IV, G(m, IV) \oplus m)$

Választott nyíltszöveges támadás

Támadás

Aktív támadó: szabadon választott üzenetek titkosításához hozzáfér (chosen plaintext attack – CPA)

Definíció (CPA megkülönböztethetetlenség kísérlet $PrivK^{cpa}_{\mathcal{A},\Pi}(n)$)

1. $k = Gen(1^n)$
2. *az $\mathcal{A}$ támadó 1^n inputon orákulumként hozzáfér $Enc_k(.)$-hez, majd kiad m_0, m_1 üzeneteket, amire $|m_0| = |m_1|$*
3. $b \in_R \{0,1\} : c = Enc_k(m_b)$ *ezt megkapja $\mathcal{A}$*
4. *$\mathcal{A}$ ismét orákulumként hozzáfér $Enc_k(.)$-hez, majd kiad $b' \in \{0,1\}$*
5. $PrivK^{cpa}_{\mathcal{A},\Pi}(n) = 1$, *ha $b = b'$, és 0 egyébként*

Választott nyíltszöveges támadás

Definíció

Egy $\Pi = (Gen, Enc, Dec)$ *titkosítás megkülönböztethetetlen választott nyíltszöveges támadás esetén (CPA-biztonságos), ha* $\forall \mathcal{A}$ *PPT támadóra* $\exists e(.)$ *elhanyagolható függvény, amire*

$$P(PrivK^{cpa}_{\mathcal{A},\Pi}(n) = 1) \leq \frac{1}{2} + e(n).$$

- nem lehet determinisztikus
- egy lehallgatás ellen bizt. $\Rightarrow$ több lehallgatás ellen bizt.
- pszeudovéletlen konstrukcióval teljesíthető

Ma is tanultam valamit

Összegzés

- Sorozat véletlen, ha nem tömöríthető
- Tökéletes vs. számítási biztonság
- PPT támadó + elhanyagolható valószínűség
- Pszeudovéletlen sorozat: "számítási" véletlen